EUREKA HACKATHON / IDEA DOCUMENT

ResilienceGuard

Governed Agentic AI for Cyber and Disaster Recovery Readiness

Know what comes back. Prove it in an isolated test.

A lightweight, vendor-independent recovery-readiness and evidence layer for operators of essential services. It checks backup evidence and system dependencies, then lets a person approve a constrained copy into an isolated test folder. The optional AI explains findings; fixed rules decide eligibility.

THE QUESTION	THE ANSWER
Can our most important services be restored after cyber or physical loss?	**Deterministic checks, dependency-aware plans and real isolated sample restores.**
THE USERS	**THE MVP**
Hospitals · utilities · government · critical suppliers	**FastAPI · React · PostgreSQL · NetworkX · local advisory model option**

A quick example: At 08:00, the 05:00 database copy is one hour older than its two-hour data-loss target. Its fingerprint matches, but the hospital app is blocked because a required directory backup is missing. No malware scan or live app restore has occurred.

For plain-language definitions and the full example, see AUDIENCE_GUIDE.md.

IMPLEMENTATION STATUS · Synthetic MVP implemented. Automated checks: 10 passed; actual sandbox copy checks: 3/3 (100.0%).

Submission snapshot: 26 October 2026 · Version 0.1.0

01 / THE CASE

The recovery gap

Critical services depend on data, identity, networks, power, people and facilities. A backup job can be green while its copy is stale, altered, trapped in the failed site, dependent on unavailable identity, or never successfully restored. During a ransomware event or physical disaster, teams need to establish what can return, in what order, and what evidence supports that conclusion.

ResilienceGuard turns that question into a repeatable readiness assessment. It joins inventory, backup metadata, failure domains, dependency records, recovery objectives and isolated test evidence. The platform is designed to complement established backup products: it assesses recoverability across sources rather than storing enterprise data itself.

- Decision makers: CIO/CISO, continuity and disaster recovery owners, infrastructure leads, risk and assurance teams.
- Initial users: hospitals, utilities, public services and critical suppliers with small or fragmented recovery teams.
- Outcome: a defensible view of available recovery points, blockers, next steps and observed test evidence.

Working MVP: four synthetic services, five backup records, three disruption scenarios, deterministic dependency analysis, human-gated isolated file restoration, measured timing, and PDF evidence export.

02 / NEED & EVIDENCE

Why recovery assurance matters

Backup readiness is a lifecycle: make copies, protect and locate them, validate integrity, rehearse restoration, and record the result. RPO and RTO targets only become useful when they are compared with an eligible recovery point and measured recovery exercise. Data center loss and cyber incidents can overlap; the dependencies that normally provide access to backups may also be unavailable.

NIST SP 1339, finalized in June 2026, describes backups as important to OT recovery from reliability and cyber incidents and recommends recurring restore tests on non-production systems. NIST SP 800-34 Rev. 1 provides contingency-planning guidance for prioritization and recovery strategies. CSF 2.0 includes a Recover function. NATO's public 2026 resilience baseline emphasizes essential services, physical and cyber risk, cascading impacts and recovery capability. These sources inform the problem framing; the product does not certify alignment.

- NIST SP 1339: https://csrc.nist.gov/pubs/sp/1339/final
- NIST SP 800-34 Rev. 1: https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final
- NIST CSF 2.0: https://www.nist.gov/cyberframework
- NATO 2026 Baseline Requirements: https://www.nato.int/en/about-us/official-texts-and-resources/official-texts/2026/09/15/2026-resilience-baseline-requirements

The product's evidence model keeps backup existence, freshness, hash integrity, malware status and actual restore success as separate states.

03 / PRODUCT

From evidence to a safe next test

An operator chooses a disaster scenario and sees a dashboard of service availability, backup status, failure-domain reachability, dependency blockers and RPO/RTO gaps. The deterministic engine proposes a recovery order. A reviewer can create a sandbox-only restore proposal for a registered synthetic file, inspect its evidence and explicitly approve or reject it. Approval copies the file into a dedicated isolated output directory and records the measured copy/check time, SHA-256 comparison and fixture health result.

The assistant can summarize the evidence and surface uncertainties. Its optional local model receives a bounded facts package and a permitted action/evidence list. The model cannot call tools or execute restoration. If it is absent or returns invalid output, a deterministic summary is used. The approval workflow is persisted and auditable.

- Import: service catalog, backup metadata, manifest digest, location, recovery target and dependencies.
- Assess: freshness, integrity, location reachability, scenario trust and dependency readiness.
- Propose: dependency-aware sequence plus a list of uncertainties and tests to perform.
- Validate: human decision, isolated sample restore, checksum comparison, basic fixture parsing and report download.

No production connector, credential, backup-control API, destructive model tool or production write path is included.

04 / INVENTORY & SCENARIOS

A small but meaningful recovery graph

The repeatable data generator uses seed 20261026 and an explicit reference time of 2026-10-26 08:00 UTC. It creates a Hospital Care Coordination application, Clinical Records Database, Clinical Identity Service and Directory Data Store. Dependencies are explicit: the application relies on the clinical database and identity; identity depends on directory data; recovery tasks require an independent recovery network and storage. The directory service intentionally has no backup record to test cascade detection.

The primary-data-center scenario removes the primary facility and East vault while leaving the West vault and recovery site available. The ransomware scenario marks the newest database candidate corrupted and untrusted. The combined power/network scenario removes the East vault and primary access path while preserving the independent recovery site. The engine identifies the verified West database candidate as stale against its two-hour RPO and blocks the application through unavailable identity/directory dependencies.

- Five backup records across two locations, one intentionally altered snapshot and one intentionally missing service backup.
- Service-specific RPO and RTO targets, estimated restore times, retention metadata and stable evidence IDs.
- NetworkX DAG validation rejects unknown edges and cycles; deterministic traversal exposes cascading blockers.

Synthetic findings are designed for repeatable demonstration; they are not a benchmark of a real hospital or operator.

05 / AI & TRUST

Governed assistance, bounded authority

Safety-critical readiness and operation eligibility are computed by deterministic Python rules. SHA-256 detects whether the sample file matches the expected digest. It cannot establish who created the file or whether it is malware-free. The system displays malware cleanliness as unknown because no scanner runs. Actual restore success is recorded only after a real copy and validation.

An optional Ollama 0.40.11 runtime with the Qwen3 8B Apache-2.0 model can produce an advisory summary. The prompt permits only supplied findings and existing action IDs. Responses are schema-checked and unknown evidence/action IDs are rejected. Natural-language claims can still be wrong, so model output is labeled advisory and asks for human review. Default mode is deterministic and works offline.

- No LangGraph: one linear approval state machine is persisted with SQLAlchemy and does not need agent checkpointing.
- Pending actions cannot be executed. Approved operations are fixed to a fixture copy under RESTORE_ROOT.
- Demo scope has no login, role separation, quorum approval, antivirus or immutable storage; operational deployment needs these controls.

A hash match is not a clean-data verdict. The MVP restores only synthetic JSON and does not start a database server or application.

06 / IMPLEMENTATION

Local-first, deployable foundation

The API uses FastAPI, Pydantic, SQLAlchemy and PostgreSQL 18 in Docker Compose, with SQLite for direct single-user local operation. React and TypeScript power the dashboard and workflow. NetworkX evaluates dependencies. The fixture source is mounted read-only; a separate volume holds isolated restore output. ReportLab creates evidence PDFs. PptxGenJS and python-docx generate the hackathon submission materials.

Technology versions are pinned and dependency audits are run. The initial deployment intentionally avoids a distributed object store because local files are enough for the synthetic dataset. MinIO upstream was archived in April 2026; a production object-storage connector should evaluate current maintained alternatives and validate API compatibility rather than adding an unneeded service to the MVP.

- Compose starts Postgres, API and UI on localhost; fixture volume is read-only and restore data is isolated.
- No actual customer, patient, military or production data is required.
- The optional LLM profile is separate because model downloads, memory and hardware requirements vary.

Architecture is designed for adapter-based expansion; vendor integrations, cloud controls and operations hardening are future work.

07 / EVALUATION

Measured synthetic results

The submitted automated suite recorded 10 passing tests and 0 failures. The synthetic evaluation checked 5/5 (100.0%) expected SHA-256 classifications, 5/5 (100.0%) freshness classifications, and 12/12 (100.0%) service/scenario dependency labels.

Across 3 actual local sandbox file-copy runs, mean measured copy/hash/fixture-check time was 0.581 ms. These small synthetic file results are not application RTO. The evaluation compared the rule-only baseline with the deterministic assistant fallback; allowed action IDs matched exactly. No Ollama/Qwen3 inference was run, so model accuracy is not measured.

- Approved isolated copy + file hash + fixture validation: 3/3 (100.0%).
- Unauthorized/untrusted restore prevention: 2/2 (100.0%).
- Evidence/action grounding against rule-only baseline: 1/1 (100.0%).
- All findings are synthetic and repeatable; no real data center or threat environment was exercised.

Measured only after execution. Local generative-model accuracy and actual malware cleanliness remain untested.

08 / CUSTOMER & COMMERCIAL

A readiness layer that complements existing tools

Economic buyers may include a CIO, CISO, COO, chief risk officer or continuity leader. Operational users include backup administrators, infrastructure teams, security incident responders and auditors. Deployment options include customer-hosted on-premises/private cloud, a managed isolated service, or a partner-delivered assessment. A pilot can normalize one service catalog, model critical dependencies, configure a small scenario set and run a supervised recovery exercise.

Rubrik, Veeam and Cohesity already sell recovery orchestration, isolated testing, clean-room workflows or related security capabilities. ResilienceGuard's proposed positioning is vendor-independent evidence aggregation across existing backup systems and simultaneous cyber/physical disruption. It is not a replacement or a claim of capability superiority. Vendor interoperability and buyer demand need discovery interviews and connector pilots.

- Illustrative first-year per-customer assumptions: $18,000 implementation + $48,000 annual license + $12,000 annual support.
- Illustrative direct delivery/support cost: $18,000 per customer; recurring fees and support drive follow-on revenue.
- Potential revenue: readiness assessment, integration/implementation, annual subscription, annual support and exercises.

The financial case is a planning model only. Prices, delivery effort, overhead, customer willingness to pay and margin have not been market-verified.

09 / RISKS & NEXT

Build trust through evidence

The most serious risk is a readiness score that overstates safety. Incomplete dependency data can hide a blocker; a digest does not prove authenticity or malware absence; optional model prose can make unsupported claims; a local demo approval is not production identity. The MVP counters those limits with deterministic gates, explicit unknown states, read-only fixtures, confined output paths, a human decision and visible synthetic labels.

Next work should prioritize authenticated users and independent approvals, signed manifests backed by external keys, antivirus/EDR integration in an isolated lab, schema adapters for existing backup products, more complete recovery dependencies, actual app/database health probes and an OpenTelemetry export with a reviewed privacy model. Pilot validation should compare assessments against existing tabletop/recovery exercises and track observed RPO/RTO outcomes over time.

- Phase 1: interviews and a supervised hospital/utility pilot with synthetic or de-identified inventories.
- Phase 2: vendor-neutral ingestion, role-based approval, deployment profiles and customer-owned evidence retention.
- Phase 3: validated clean-room integrations, exercise scheduling, aggregate reporting and managed support.

ResilienceGuard's promise is not that an outage cannot happen. It is that teams can see recovery evidence, blockers and uncertainty before the outage does.

References and assumptions

- NIST SP 1339, OT Backup Quick Start Guide, June 2026. https://csrc.nist.gov/pubs/sp/1339/final
- NIST SP 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems. https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final
- NIST Cybersecurity Framework 2.0. https://www.nist.gov/cyberframework
- NATO 2026 Resilience Baseline Requirements, 15 September 2026. https://www.nato.int/en/about-us/official-texts-and-resources/official-texts/2026/09/15/2026-resilience-baseline-requirements
- Rubrik Cyber Recovery. https://www.rubrik.com/products/cyber-recovery
- Veeam Recovery Orchestrator overview. https://helpcenter.veeam.com/docs/vro/userguide/overview.html
- Cohesity Clean Room. https://www.cohesity.com/solutions/clean-room/
- MinIO upstream repository status. https://github.com/minio/minio

Interpretation

Standards and vendor pages establish context, not proof of product compliance or competitive superiority. Adoption, customer value, price, implementation effort and financial scenarios are hypotheses for validation. Real deployment requires threat modeling, privacy/security review, customer-owned recovery policy and integrations tested in a representative isolated environment.

Illustrative first-year unit assumptions

Implementation $18,000 + annual license $48,000 + annual support $12,000; direct delivery/support cost $18,000 per customer. These are planning assumptions, not market-verified prices or quotes.